

# Northstar Labs Incident Response Policy

*Version 1.0 – Internal Policy Document*

Northstar Labs is committed to responding to information security incidents quickly, effectively, and consistently in order to minimise operational disruption, protect customer data, and maintain regulatory compliance. This policy defines the organisation's approach to incident identification, reporting, response, escalation, communication, and post-incident review activities.

|                  |                           |
|------------------|---------------------------|
| Document Owner   | Information Security Lead |
| Company          | Northstar Labs            |
| Version          | 1.0                       |
| Review Frequency | Annually                  |
| Classification   | Internal Use              |
| Effective Date   | 18 May 2026               |

## 1. Incident Reporting Process

All employees, contractors, and third parties must immediately report suspected or confirmed security incidents to the Information Security Team. Security incidents may include, but are not limited to: • Unauthorised access attempts • Malware infections • Phishing attacks • Data breaches • Lost or stolen devices • Service disruptions affecting customers Incidents must be reported through approved communication channels including the internal incident reporting mailbox or designated incident management platform. The Information Security Team is responsible for logging, triaging, and coordinating incident response activities.

## 2. Response Timelines

Northstar Labs aims to acknowledge and assess all reported security incidents promptly. Target response timelines are as follows: • Critical incidents: Initial response within 1 hour • High severity incidents: Initial response within 4 hours • Medium severity incidents: Initial response within 1 business day • Low severity incidents: Initial response within 2 business days Incident response activities should prioritise containment, eradication, recovery, and restoration of affected systems and services.

## 3. Severity Classification

Security incidents are classified according to their potential impact on confidentiality, integrity, availability, customers, and business operations. Classification levels include: • Critical – Significant business disruption, major data breach, or widespread service outage. • High – Serious security event with potential customer or operational impact. • Medium – Contained issue with limited operational impact. • Low – Minor issue or policy violation with minimal risk. Incident severity may be reassessed as additional information becomes available.

## **4. Notification Process**

Relevant internal stakeholders must be notified of security incidents based on severity, business impact, and regulatory obligations. Where required, customers, regulators, or third-party partners may be informed in accordance with contractual commitments, legal requirements, and UK GDPR obligations. Communication regarding active incidents must be coordinated through authorised personnel only to ensure consistency and accuracy. Incident updates should be documented throughout the response lifecycle.

## **5. Post-Incident Reviews**

All high and critical severity incidents must undergo a formal post-incident review. Reviews should identify: • Root cause • Impact assessment • Response effectiveness • Corrective actions • Preventative improvements Lessons learned must be documented and shared with relevant teams where appropriate. Follow-up actions should be tracked to completion to reduce the likelihood of similar incidents occurring in the future.